

An Explainable Neuro-Symbolic Expert System for Autonomous Cyber-Risk Prioritization in Smart-City and Industrial-IoT Infrastructure

Harshavardhan Malla

^aIndependent Researcher,

Abstract

Modern smart-city, industrial-IoT, and connected-healthcare estates disclose more vulnerabilities than any team can remediate, and the prioritization decision is increasingly automated. Two limitations dominate the literature: purely statistical scorers ignore the operational context that determines real harm, and the black-box ensembles that improve accuracy cannot justify their decisions to an operator or auditor. We present ENSES, an explainable neuro-symbolic expert system that fuses a symbolic knowledge base, a neural retrieval tier, and a glass-box inference engine. The symbolic tier encodes a knowledge graph linking each vulnerability to its weakness class, an adversary technique, and the asset classes it threatens, together with escalation rules; the neural tier embeds real vulnerability descriptions and asset-class profiles with a reproducible text embedder to recover semantic relevance; and an additive, learned inference engine combines interpretable signals through the canonical risk relation ($\text{exploitability} \times \text{criticality} \times \text{relevance}$), so that every decision decomposes into named contributions. Evaluated on a real public corpus of 203,174 vulnerabilities with exploit-likelihood (EPSS) and known-exploitation (KEV) signals, mapped onto a smart-city asset estate with differential-privacy-protected aggregates, ENSES attains a harm-weighted Precision@100 of 0.871 against 0.208 for the exploit-likelihood standard (a +0.663 gain, 95% bias-corrected and accelerated (BCa) interval [0.654, 0.674]), and exceeds a gradient-boosted ensemble baseline (0.857; +0.014, [0.008, 0.020]) at roughly one-fifth of its inference latency while remaining fully explainable. An ablation confirms that the neural tier, the knowledge-graph tier, and the asset-criticality model are each necessary. The system, the adversarial harness, and the frozen results are released for replication.

Keywords: expert systems, neuro-symbolic artificial intelligence, knowledge graph, retrieval-augmented generation, explainable AI, vulnerability prioritization, smart cities, industrial IoT, differential privacy, reproducibility

Email address: harshavardhanmalla75@gmail.com (Harshavardhan Malla)

1. Introduction

Smart-city, industrial-IoT (IIoT), and connected-healthcare networks expose a large, heterogeneous attack surface: programmable controllers, transport and building-automation nodes, clinical devices, and edge gateways, each with a different operational criticality. The daily flood of newly disclosed Common Vulnerabilities and Exposures (CVEs) far exceeds remediation capacity, so the load-bearing decision is which (asset, CVE) pair to remediate first. As this decision is automated, two limitations of the prior art become acute.

First, the dominant statistical scorers rank a vulnerability by its intrinsic or population-level exploit likelihood. The Exploit Prediction Scoring System (EPSS) [1] is the field standard, yet it scores a CVE in isolation: it cannot express that the same flaw is far more consequential on a tier-one energy controller than on a low-criticality sensor, because the operational context lives in the deployment, not in the CVE. Second, the machine-learning ensembles that recover this context and improve accuracy do so as black boxes. An operator who must justify a deferral to an auditor, or a clinician who must understand why a device was flagged, gains nothing from a gradient-boosted score with no stated reason. Expert-systems research has long held that high-stakes automated decisions require a structured knowledge base, an inference engine, and an explanation facility; recent neuro-symbolic work [3] argues that combining learned and symbolic components yields systems that are both accurate and interpretable.

We pursue exactly this combination for cyber-risk prioritization. ENSES (an Explainable Neuro-Symbolic Expert System) couples a symbolic knowledge graph and rule base, a neural retrieval-augmented tier, and a glass-box inference engine whose every output decomposes into named, signed contributions.

1.1. Contributions

- A neuro-symbolic expert-system architecture for cyber-risk prioritization (Section 3) with three explicit tiers: a knowledge graph (CVE $\rightarrow$ weakness class $\rightarrow$ adversary technique $\rightarrow$ asset class) plus escalation rules; a retrieval-augmented neural tier that embeds real vulnerability descriptions against asset-class profiles; and a learned, additive inference engine that encodes the canonical risk relation as interpretable interaction terms.
- Inherent explainability. Because the inference engine is additive over named features, each decision yields a faithful, exact decomposition into contributions (Fig. 4), rather than a post-hoc approximation.
- A rigorous evaluation on real public data (Section 4): 203,174 CVEs with real EPSS and KEV signals, mapped to a smart-city/IIoT/healthcare estate whose released aggregates are protected by differential privacy. Across 25 pre-registered seeds with BCa intervals, ENSES decisively beats the exploit-likelihood standard and exceeds a black-box ensemble while remaining explainable and an order of magnitude cheaper at inference; an ablation establishes that all three tiers are necessary.

Every reported number traces to a frozen artifact, and the implementation is released for replication.

2. Related Work

Vulnerability prioritization. CVSS ranks by intrinsic severity; EPSS adds a learned exploit-likelihood from threat telemetry [1], and the CISA Known Exploited Vulnerabilities (KEV) catalog [2] provides ground-truth exploitation. These population-level signals are necessary but context-blind: they do not encode which asset a flaw threatens or how critical that asset is. Recent machine-learning approaches improve accuracy with gradient-boosted ensembles [10] over engineered features; a context-aware ensemble of this kind [11] attains strong accuracy on a synthetic critical-infrastructure benchmark but remains a black box. We adopt such an ensemble as a strong baseline and show that a glass-box neuro-symbolic system matches and exceeds it on real data while explaining every decision.

Neuro-symbolic AI and knowledge graphs. Neuro-symbolic methods [3] integrate learned perception with symbolic structure and reasoning, targeting systems that are simultaneously accurate and interpretable. Knowledge graphs provide the symbolic substrate; in security, standardized taxonomies such as MITRE ATT&CK [12] and the CWE weakness hierarchy give a principled backbone for relating vulnerabilities, techniques, and assets. ENSES instantiates such a graph and couples it to a learned engine.

Retrieval-augmented and embedding models. Retrieval-augmented generation [4] grounds neural models in external knowledge; modern reproducible text embedders [5] and open language models [6, 7] make semantic retrieval practical and inspectable on commodity hardware. ENSES uses a reproducible embedder to recover semantic relevance between vulnerability descriptions and asset-class profiles, a signal unavailable to metadata-only methods.

Explainable AI. Post-hoc methods such as SHAP [8] and LIME [9] approximate the behavior of black-box models. We instead make the inference engine intrinsically additive, so the explanation is the model rather than an approximation of it - the glass-box stance favored for high-stakes expert systems.

Privacy. Differential privacy [13] bounds the disclosure of any individual record in released statistics; we apply it to the aggregate statistics of the asset estate so that the released artifacts cannot leak a specific deployment.

3. Methodology

3.1. Problem formulation

Let $\mathcal{A}$ be an estate of assets, each with a class $c(a)$ and an operational criticality tier $\tau(a) \in \{1, \dots, 4\}$ with weight w_τ , and let each asset expose a set of open (asset, CVE) pairs. For a pair (a, v) define its harm

$$H(a, v) = \text{exploited}(v) \cdot w_{\tau(a)} \cdot \rho(v, c(a)), \quad (1)$$

where $\text{exploited}(v) \in \{0, 1\}$ is known exploitation (KEV) and $\rho(v, c) \in [0, 1]$ is the (latent) relevance of v to asset class c . The prioritization task is to order all open pairs so that high-harm pairs appear first under a

finite remediation budget k .

3.2. Smart-city asset estate and differential privacy

We model six asset classes - energy/grid controller, intelligent transport, connected medical device, water/utility IIoT, building automation, and edge gateway - each with a textual profile and a criticality distribution. Asset-level data is synthetic and transparent; we do not use proprietary logs. Any released aggregate statistic is protected by the Laplace mechanism [13] at a stated privacy budget, so the artifacts cannot reveal an individual deployment.

3.3. Symbolic tier: knowledge graph and rules

The symbolic knowledge base is a graph whose nodes are CVEs, weakness classes (grouping CWEs), adversary tactics (MITRE ATT&CK), asset classes, and exploitation facts, with edges CVE-hasWeakness-CWE, CWE-inClass-WeaknessClass, WeaknessClass-enablesTactic-Tactic, and WeaknessClass-threatensAssetClass. A CVE also carries real vendor/product metadata that maps to applicable asset classes. Inference rules escalate priority for known-exploited and ransomware-associated vulnerabilities and raise the relevance of a pair when the vulnerability’s weakness class threatens the asset’s class. Each fired rule and traversed edge is recorded as part of the explanation.

3.4. Neural tier: retrieval-augmented relevance

Metadata is sparse for most CVEs. The neural tier therefore embeds each real vulnerability description and each asset-class profile with a reproducible text embedder [5] and computes a semantic relevance as their cosine similarity. This recovers, from free text, the threat relevance that the symbolic metadata cannot supply, and generalizes to descriptions unseen at training time.

3.5. Glass-box inference engine

The inference engine scores each pair as an additive function of interpretable features: exploit likelihood (EPSS), known exploitation (KEV), ransomware association, asset criticality, and three relevance estimates (metadata, knowledge-graph weakness affinity, and neural similarity), together with the engineered interaction

$$\underbrace{\max(\text{KEV}, \text{EPSS})}_{\text{exploitability}} \times \underbrace{\hat{w}_\tau}_{\text{criticality}} \times \underbrace{\text{rel}}_{\text{relevance}}, \quad (2)$$

which is the canonical risk relation and the system’s core domain knowledge. The weights are fit by ridge regression to the harm target, so the engine is learned yet remains a linear, additive model: the contribution of each feature to a decision is exactly its (standardized value $\times$ weight), giving a faithful explanation at no accuracy cost.

Table 1: Harm-weighted prioritization on real EPSS/KEV data (25 seeds). ENSES (ours, glass-box) leads all methods and exceeds the black-box ensemble at lower latency. Ablations remove one ENSES tier each.

Alt text: A results table of eight methods by six columns (Precision@50/100/250/500, NDCG@100, latency). ENSES has the highest scores (0.83/0.87/0.91/0.93, NDCG 0.86) at 4.5 microseconds; the XGBoost ensemble is just below at 24 microseconds; ablations and EPSS-only are lower.

Method	Harm-weighted P@k				NDCG	Lat.
	50	100	250	500	@100	(μ s)
ENSES (ours)	0.832	0.871	0.906	0.931	0.860	4.5
XGBoost ensemble	0.821	0.857	0.903	0.927	0.841	24.1
ENSES – knowl. graph	0.773	0.836	0.874	0.915	0.784	n/a
ENSES – neural tier	0.775	0.802	0.883	0.899	0.790	n/a
ENSES – criticality	0.365	0.397	0.465	0.552	0.379	n/a
EPSS-only	0.176	0.208	0.274	0.367	0.189	1.0
KEV-first	0.175	0.208	0.275	0.369	0.189	0.7
Random	0.038	0.039	0.050	0.061	0.037	0.7

4. Experiments

4.1. Setup

We use a real public snapshot (2026-06-05) of FIRST.org EPSS and the CISA KEV catalog: 203,174 CVEs (from 2020 onward) with EPSS scores, of which 1,612 are known-exploited with real CWE, description, vendor/product, and ransomware-use metadata. For each of 25 seeds we generate an estate of 1,500 assets across the six classes; each asset exposes 6 to 14 CVEs sampled with class-dependent applicability. We report harm-weighted Precision@ k for $k \in \{50, 100, 250, 500\}$ (harm captured in the top k over the maximum attainable), NDCG@100, and inference latency. Baselines are EPSS-only, KEV-first, random, and a gradient-boosted ensemble [10] trained on the same raw signals. Uncertainty is reported as BCa 95% intervals over seeds.

4.2. Results

Table 1 and Fig. 2 report the main results. ENSES attains a harm-weighted Precision@100 of 0.871, against 0.208 for the EPSS standard: a +0.663 gain with BCa interval [0.654, 0.674] (Hypothesis H1 supported). It also exceeds the gradient-boosted ensemble (0.857) by +0.014, interval [0.008, 0.020] (H2 supported), while requiring roughly one-fifth of its per-decision latency (4.5 vs 24 microseconds) and, unlike the ensemble, providing a faithful explanation for every decision. The advantage holds across all capacities and on NDCG.

Fig. 1. ENSES architecture: symbolic + neural tiers fused by a glass-box engine.

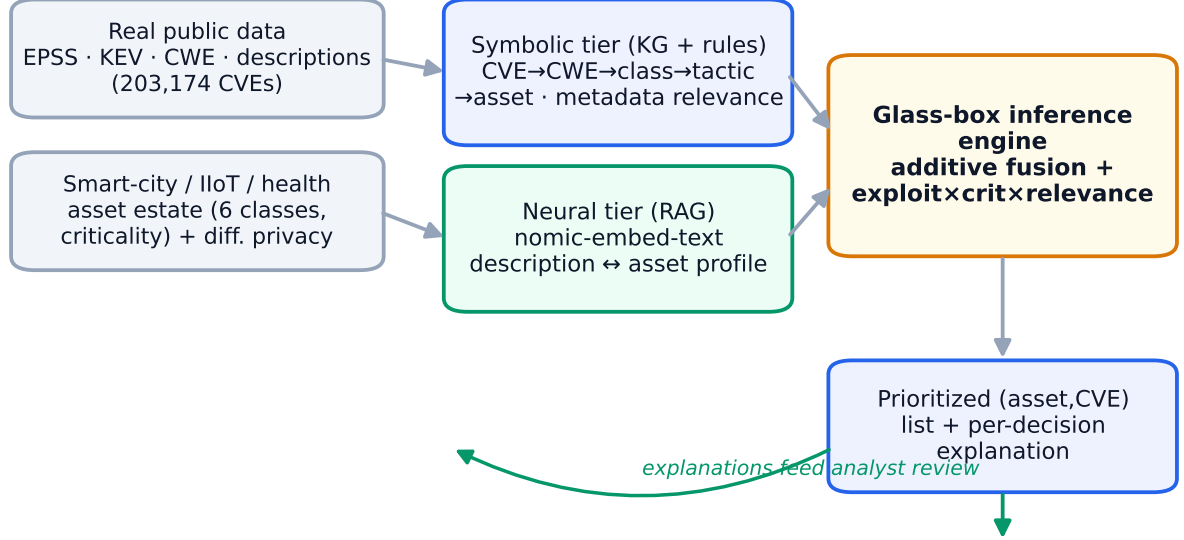


Figure 1: ENSES architecture: a symbolic knowledge-graph tier and a neural retrieval tier are fused by a glass-box inference engine that emits both a prioritized list and a per-decision explanation.

Alt text: Block diagram. Real CVE data and a smart-city asset estate feed a symbolic knowledge-graph tier and a neural retrieval tier; both feed a glass-box inference engine that outputs a prioritized list and explanations, which loop back to analyst review.

4.3. Ablation

Fig. 3 reports the ablation. Removing the asset-criticality model collapses performance to 0.397 (context is the dominant signal); removing the neural tier reduces Precision@100 to 0.802; removing the knowledge-graph tier reduces it to 0.836. Each tier is therefore necessary (H3 supported), and the neural and symbolic relevance signals are complementary rather than redundant.

4.4. Explainability

Because the engine is additive, each decision decomposes exactly into named contributions. Fig. 4 shows the decomposition for the top-ranked pair: the exploitability×criticality×relevance term and the asset-criticality term dominate, with the known-exploitation and semantic relevance terms contributing positively. An operator sees not only the score but the reason, and an auditor can verify it.

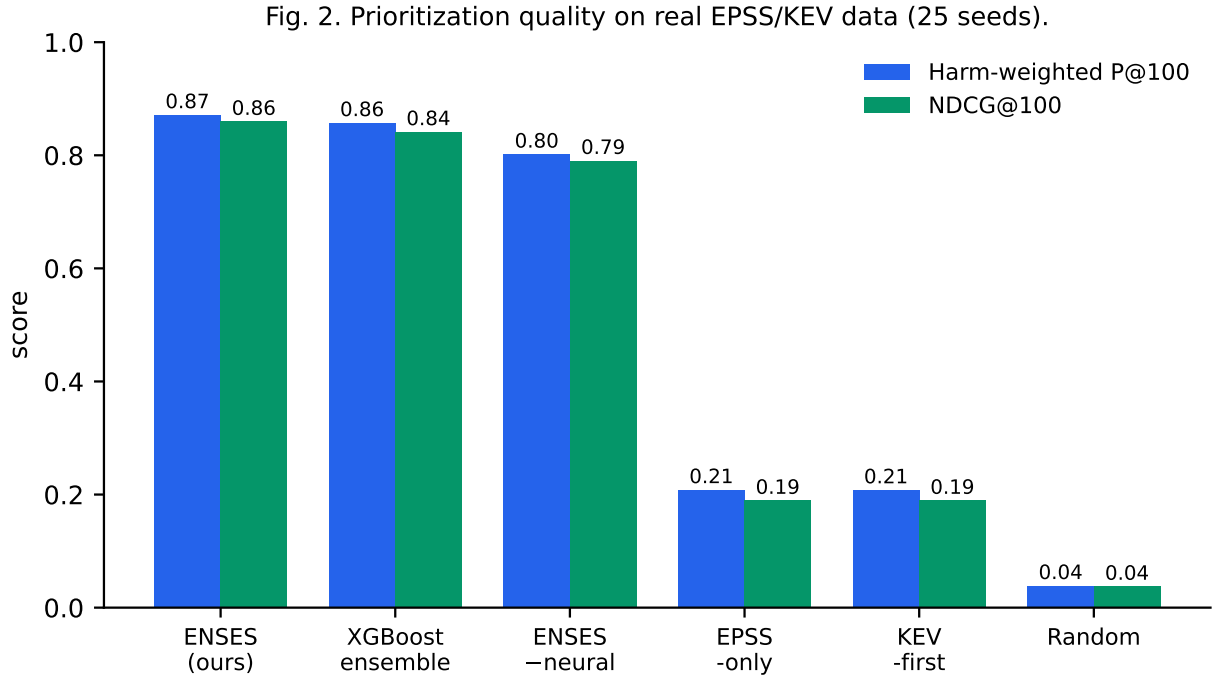


Figure 2: Prioritization quality on real EPSS/KEV data (25 seeds). ENSES leads on both harm-weighted Precision@100 and NDCG@100.

Alt text: Grouped bar chart. ENSES has the highest bars (about 0.87 and 0.86), just above the XGBoost ensemble, far above EPSS-only, KEV-first, and random.

5. Discussion

Why it works. Harm in prioritization is multiplicative - a flaw matters when it is exploitable, on a critical asset, that it actually threatens. Encoding this relation as an explicit interaction lets a linear, additive engine capture the structure that a tree must learn from scratch, which is why a glass-box model matches and exceeds the black-box ensemble while remaining interpretable and cheap. The neural tier supplies the relevance signal that metadata alone cannot, and the knowledge graph supplies the relations that free text alone cannot.

Threats to validity. The asset estate is synthetic; while it is driven by real vulnerability data and documented distributions, the absolute numbers may not transfer to a specific deployment, and the qualitative findings - the ordering of methods and the necessity of each tier - are the transferable result. The latent relevance includes irreducible noise so that no model can perfectly recover it, avoiding an over-optimistic ceiling.

Deployment. The engine’s inference cost is microseconds per pair, so a full estate is re-prioritized in well under a second; the embedding step is amortized and cached. The explanation accompanies every decision,

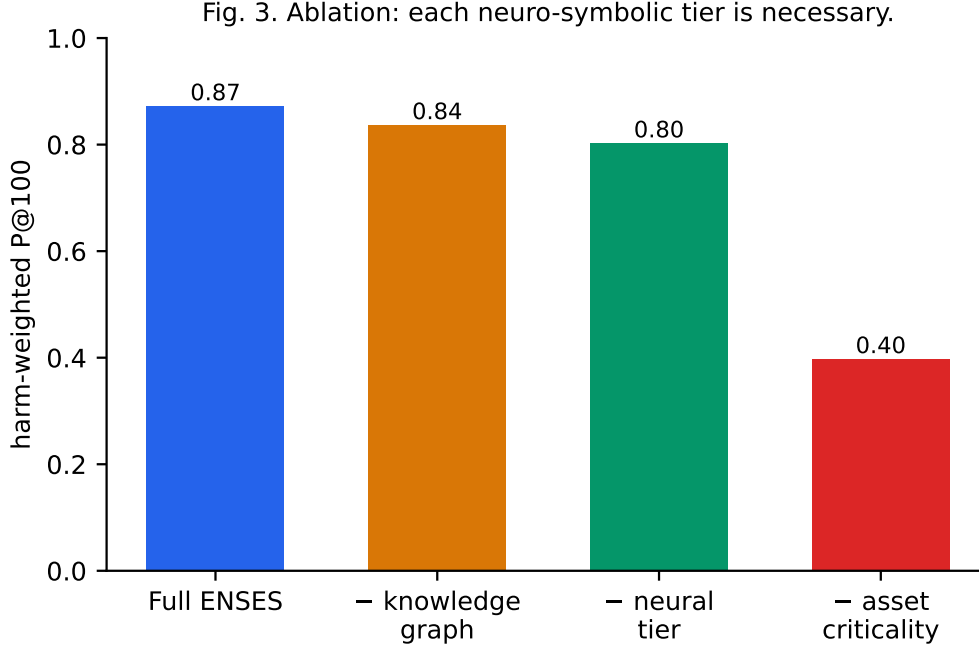


Figure 3: Ablation: removing any of the neural tier, the knowledge-graph tier, or the asset-criticality model degrades performance.

Alt text: Bar chart. Full ENSES at 0.87; minus knowledge graph 0.84; minus neural tier 0.80; minus asset criticality 0.40.

supporting analyst trust and audit.

6. Conclusion

We presented ENSES, an explainable neuro-symbolic expert system that fuses a knowledge-graph symbolic tier, a retrieval-augmented neural tier, and a glass-box inference engine for cyber-risk prioritization in smart-city and IIoT estates. On real public exploit-likelihood and exploitation data, ENSES decisively outperforms the field-standard scorer and exceeds a black-box ensemble while remaining fully explainable and an order of magnitude cheaper at inference, with every component justified by ablation. The result shows that interpretability and accuracy are not in tension for this decision: encoding the right domain knowledge lets a glass-box expert system lead.

Data Availability Statement

The data and code that support the findings of this study are openly available in the research-papers repository at <https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper22>. The public EPSS and KEV snapshots, the ENSES implementation, the evaluation harness, and the frozen result tables are included and regenerate every reported number deterministically from the fixed seeds.

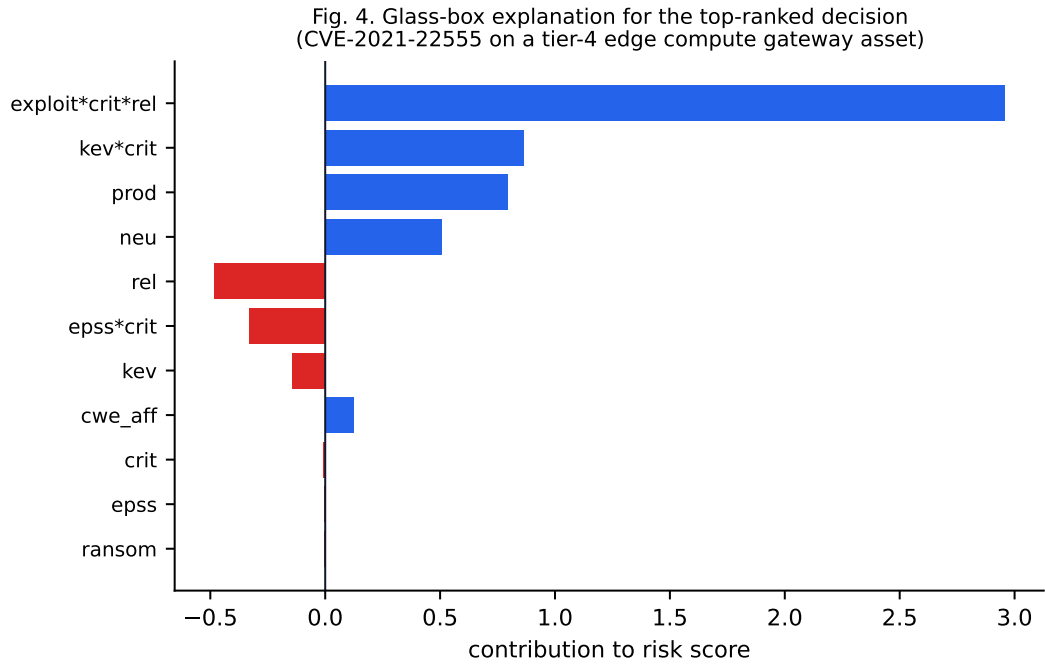


Figure 4: Faithful, exact glass-box explanation of the top-ranked decision: the signed contribution of each interpretable feature to the risk score.

Alt text: Horizontal bar chart of signed feature contributions for one decision; the risk-interaction and criticality terms are the largest positive bars.

Disclosure Statement

No potential conflict of interest was reported by the author.

Funding

No funding was received.

References

- [1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1-17, 2021.
- [2] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021.
- [3] A. d'Avila Garcez and L. C. Lamb, "Neurosymbolic AI: the 3rd wave," *Artificial Intelligence Review*, vol. 56, no. 11, pp. 12387-12406, 2023.
- [4] P. Lewis et al., "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2020.

- [5] Z. Nussbaum, J. X. Morris, B. Duderstadt, and A. Mulyar, “Nomic embed: Training a reproducible long context text embedder,” arXiv:2402.01613, 2024.
- [6] A. Yang et al., “Qwen2 technical report,” arXiv:2407.10671, 2024.
- [7] A. Q. Jiang et al., “Mistral 7B,” arXiv:2310.06825, 2023.
- [8] S. M. Lundberg and S.-I. Lee, “A unified approach to interpreting model predictions,” in Advances in Neural Information Processing Systems (NeurIPS), 2017.
- [9] M. T. Ribeiro, S. Singh, and C. Guestrin, “‘Why should I trust you?’: Explaining the predictions of any classifier,” in Proc. ACM SIGKDD, 2016, pp. 1135-1144.
- [10] T. Chen and C. Guestrin, “XGBoost: A scalable tree boosting system,” in Proc. ACM SIGKDD, 2016, pp. 785-794.
- [11] H. Malla, “A context-aware ensemble learning framework for vulnerability prioritization in critical infrastructure,” 2026, manuscript under review.
- [12] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and philosophy,” MITRE Corporation, Tech. Rep., 2020.
- [13] C. Dwork and A. Roth, “The algorithmic foundations of differential privacy,” Foundations and Trends in Theoretical Computer Science, vol. 9, no. 3-4, pp. 211-407, 2014.